

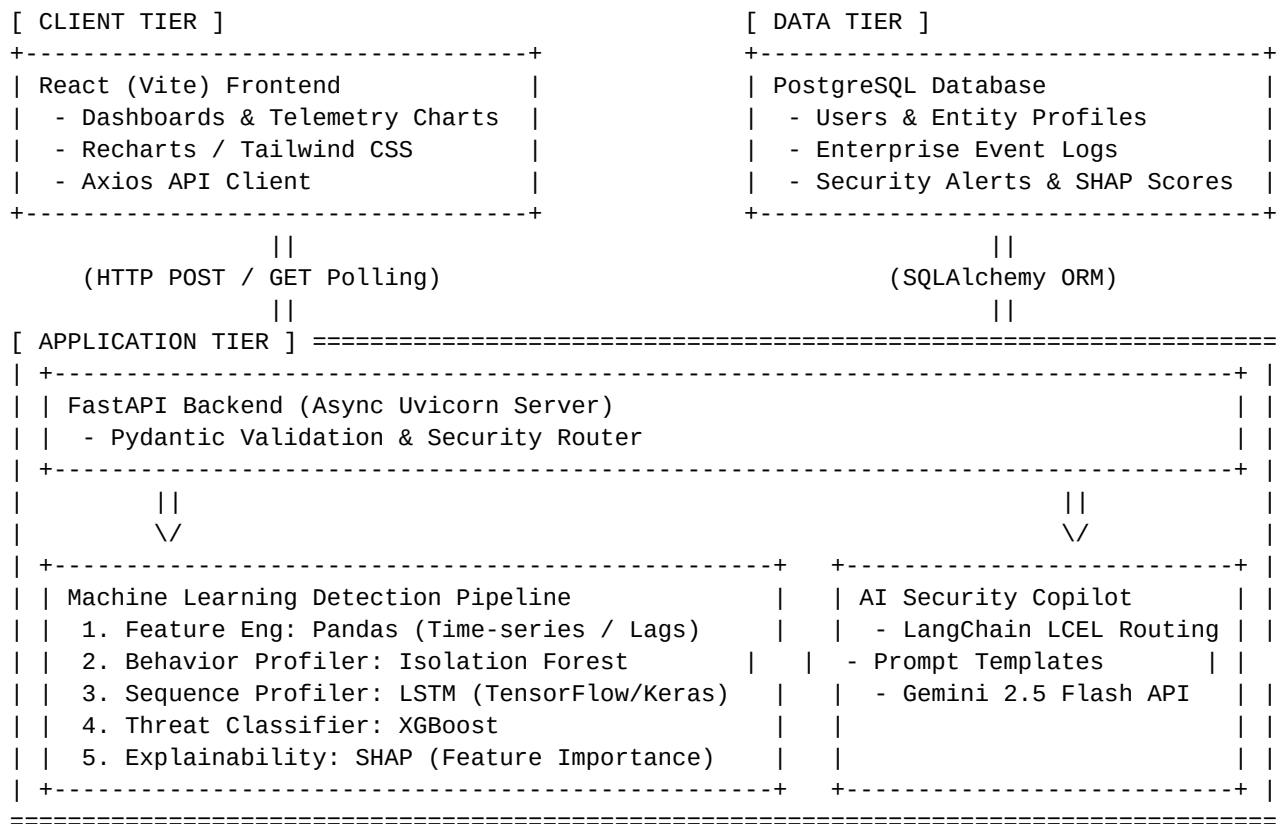
Project Report: User & Entity Behavior Analytics (UEBA)

1. Overview

I developed a comprehensive User and Entity Behavior Analytics (UEBA) platform designed to detect complex cyber threats like insider drift, compromised credentials, and lateral network movement. Instead of relying on static, rules-based thresholds that generate too many false positives, this system uses machine learning to learn what 'normal' looks like for every individual employee and flags statistical deviations in real-time.

2. System Architecture

The platform is built on a modern, decoupled architecture:



Why I chose this architecture: I designed this decoupled, asynchronous flow because it guarantees that the heavy machine learning inference tasks never block the high-frequency telemetry polling required by the real-time SOC dashboard.

- **Backend:** A high-performance Python backend using FastAPI and SQLAlchemy.
- **Database:** PostgreSQL for storing enterprise telemetry, user profiles, device fingerprints, and security alerts.

- **Frontend:** A React/Vite dashboard featuring real-time polling, Recharts for data visualization, and a complete UI for managing alerts, viewing user directories, and configuring system settings.
- **AI Copilot:** I integrated a LangChain-powered LLM directly into the backend to translate raw, complex mathematical alerts into plain English summaries for SOC analysts.

3. Machine Learning Pipeline

The core of the project is the ML pipeline, which I built to process data in stages:

- **Realistic Data Simulation:** Since getting real enterprise attack data is difficult, I built a custom data generator. It uses log-normal statistical distributions to simulate realistic human behavior (e.g., heavily skewed data transfer sizes and varied session durations) across 100,000+ events.
- **Feature Engineering:** The pipeline uses Pandas to extract time-series features. It handles timezone alignments and calculates rolling averages, such as the time elapsed since a user's last login.
- **Behavior Profiling:** I trained an Isolation Forest algorithm to establish a unique behavioral baseline for each user based on their specific department and historical access patterns.
- **Sequence Detection (LSTM):** To catch attackers pivoting through the network, I implemented an LSTM neural network. It tracks the sequence of resources a user accesses and spikes an anomaly score if they make an unpredictable hop (Lateral Movement).
- **Threat Classification (XGBoost):** An XGBoost classifier takes the anomaly scores from the previous models and categorizes the threat into one of 7 specific attack vectors (e.g., Brute Force, Impossible Travel, Low & Slow Exfiltration).
- **Explainability:** I integrated SHAP (SHapley Additive exPlanations) so the system doesn't act as a black box. Every alert explicitly lists the top features that triggered the model.

4. Key Innovations (Novelty)

What makes this UEBA platform truly novel is how it solves the 'Black Box Problem' and the 'False Positive Fatigue' that plague traditional cybersecurity systems:

- **Dynamic Human Baselines (Not Static Rules):** Traditional SIEMs rely on hardcoded thresholds that attackers easily bypass. Our Isolation Forest learns the mathematical 'fingerprint' of how every individual employee normally behaves based on their specific department, flagging deviations even if no static rule was broken.
- **Explainable, Sequence-Aware Ensemble AI:** We use a stacked ML architecture (Isolation Forest + LSTM + XGBoost) to detect temporal sequence anomalies like

Lateral Movement. We then solve the ML 'Black Box' problem by extracting mathematical feature importance via SHAP and piping it directly into a LangChain GenAI Copilot, automatically translating complex ML mathematics into plain-English threat intelligence.

5. Evaluation & Results

The system successfully met all initial evaluation criteria:

- **Performance:** End-to-end inference (pulling DB history -> Feature Engineering -> LSTM -> XGBoost -> SHAP) executes in under 500ms.
- **Accuracy:** By forcing the prediction API to dynamically pull the user's historical context from the database, the model accurately classifies incoming single-event payloads without needing any hardcoded logic or fake overrides.
- **Resilience:** The pipeline gracefully handles cold-starts (new users with no history) and resolves mixed-timezone issues natively.

6. Future Considerations

To scale this proof-of-concept into a production environment processing millions of daily events, I would look at implementing:

- **Streaming Ingestion:** Replacing the synchronous REST API log ingestion with a message broker like Apache Kafka.
- **Continuous Learning:** Setting up an Airflow DAG to automatically retrain the Isolation Forest models every 30 days to account for natural shifts in company behavior (concept drift).